

Governing Generative AI Across Financial Institutions: An SR 26-2-Compatible Framework for Generative AI Risk Control

Yiqing Wang^{1,*} Yixin Kang² Luyun Lin^{1,*} Siqi Mao^{1,*}

¹*Citigroup*, Dallas, TX, USA

²*Florida State University*, Tallahassee, FL, USA

Abstract

The release of SR 26-2 marks a significant modernization of U.S. model risk management by replacing SR 11-7 with a more risk-based and materiality-sensitive supervisory framework. However, generative and agentic AI are excluded, creating an important governance challenge for banking organizations and other financial institutions. Although generative AI may not directly estimate credit risk or make underwriting decisions, its outputs can materially affect the surrounding control environment through monitoring interpretation, policy analysis, or adverse-action language drafting. These uses may influence how regulated financial decisions are explained, challenged, documented, and governed.

This paper proposes the Generative AI Control Framework (GAICF), an SR 26-2-compatible governance framework for generative AI-enabled financial workflows. The framework translates core model risk management principles into a layered control structure for generative AI applications that operate outside the formal model boundary but remain embedded within regulated banking processes. GAICF provides a practical approach for financial institutions seeking to align emerging generative AI governance practices with the risk-based supervisory expectations reflected in SR 26-2.

Keywords: generative AI; model risk management; SR 26-2; banking regulation; AI governance

*For authors affiliated with Citigroup, the views expressed in this paper are solely those of the authors and do not reflect the views of Citigroup or any of its affiliates.

1 Introduction

The adoption of Generative AI in financial institutions has expanded beyond software development into broader knowledge-intensive workflows [1, 2]. In consumer underwriting, for example, Generative AI may not directly replace quantitative underwriting models used for default estimation, but they can support adjacent tasks such as drafting model validation reports, assisting adverse-action explanations, and summarizing human override rationales [3, 4]. Although these usages do not constitute the primary credit decision mechanism, they can still shape how credit decisions are interpreted, challenged, documented, and communicated. It raises a governance concern and regulation requirement because Generative AI-enabled workflow outputs may influence the control environment surrounding regulated credit decisions.

Banking organizations and other financial institutions have traditionally relied on U.S. supervisory guidance, particularly SR 11-7 [5], to support model risk management practices. In April 2026, SR 26-2 replaced the prior guidance and modernized supervisory expectations for model risk management [6]. However, SR 26-2 excludes generative AI and agentic AI from its formal scope. This exclusion does not imply that generative AI-enabled financial workflows are free from governance expectations. The guidance states that institutions’ broader risk management and governance practices should maintain appropriate controls for such systems. This creates a practical challenge for banks and other financial institutions: how should they govern generative AI-enabled workflows that fall outside the formal scope of SR 26-2 but may still affect regulated business processes, customer communications, risk management activities, documentation, monitoring, or control functions?

The challenge is especially significant in large financial institutions because financial activities are both analytical and communicative. A quantitative model may produce a score, forecast, risk estimate, valuation, or control signal, but the institution must also document model assumptions, monitor performance, explain results, interpret policy requirements, prepare escalation rationales, support customer or regulator communications, and maintain audit evidence. These surrounding activities are part of the governance mechanism that makes model use, risk management, and business decision-making accountable. When generative AI systems generate, summarize, interpret, or reshape the language used in these activities, the relevant risk is not limited to predictive accuracy. It also extends to institutional policy alignment, regulatory compliance, auditability, operational control, and customer protection.

This paper addresses this governance gap by proposing the Generative AI Control Framework (GAICF), a practical governance framework for generative AI-enabled workflows in large financial institutions. The framework translates SR 26-2’s model risk management concepts into a layered control structure for generative AI usage, including approved-use boundary determination, risk-tier assignment, evidence-grounded input assessment, operational-mode classification, output evaluation, monitoring, and auditability. By extending traditional model risk management concepts to the broader workflow risks created by generative AI, the GAICF provides a bridge between established model governance practices and the emerging governance needs of generative AI-enabled financial workflows.

The remainder of the paper is organized as follows. Section 2 reviews relevant regulatory guidance and research literatures on model risk management and AI governance. Section 3 introduces the

Generative AI Control Framework and its main control layers. Section 4 concludes the paper and discusses future research directions.

2 Regulatory Change and Challenge

The governance problem addressed in this paper sits at the boundary between banking model risk management and emerging AI risk management. Each source of guidance or practice is relevant to generative AI-enabled financial workflows, but none is sufficient on its own. Model risk management provides a mature control vocabulary for intended use, validation, monitoring, change management, and governance [7, 8]. Fair lending and consumer protection requirements emphasize accurate, specific, and supportable explanations when adverse action or other consumer-impacting decisions are communicated [9, 10]. Broader AI governance frameworks address trustworthiness, transparency, accountability, and human oversight [11, 12, 13]. However, these frameworks do not fully specify how financial institutions should govern generative AI systems that operate within business workflows but outside the formal model boundary. This paper addresses that gap by translating model risk management concepts into a layered governance framework for generative AI-enabled financial workflows.

2.1 SR 26-2 and the Boundary of Model Risk Management

In April 2026, the Board of Governors of the Federal Reserve System, the Office of the Comptroller of the Currency (OCC), and the Federal Deposit Insurance Corporation (FDIC) issued the revised supervisory guidance on model risk management, referenced as SR 26-2 [6]. The revised guidance replaces SR 11-7 and modernizes supervisory expectations for model risk management after more than a decade of changes in modeling practice [14]. The most important shift from SR 11-7 to SR 26-2 is on a change in model risk management boundary-setting. SR 26-2 preserves core principles such as validation, monitoring, governance, and effective challenge, while adopting a more risk-based and materiality-sensitive approach.

Moreover, SR 26-2 excludes generative AI and agentic AI from the formal scope because these technologies are novel and rapidly evolving. However, it should not be interpreted as an absence of governance expectations on those AI models. The guidance states explicitly that banking organizations should use broader risk management and governance practices to determine appropriate controls for tools, processes, or systems not covered by the document. This boundary-setting issue is especially important for agentic AI, where individually acceptable skills may create new risks when combined into multi-step workflows [15].

These changes create new challenges for financial risk management and governance. A generative AI system may not estimate probability of default, assign a credit score, produce a valuation, or generate a capital estimate in the same manner as a traditional quantitative model. Nevertheless, it may be used to draft model validation reports, interpret monitoring alerts, explain model-output movements, summarize risk drivers, prepare escalation rationales, or support customer-facing communications. These activities can influence how approved models are understood, challenged, documented, governed, and communicated. Therefore, governance of generative AI-enabled workflow

risk remains necessary and important even when the generative AI system itself is outside the formal model boundary.

2.2 Illustrative Domain: Consumer Credit, Fair Lending, and Adverse-Action Explanation Duties

Although the GAICF is designed for generative AI-enabled workflows across large financial institutions, consumer credit provides a useful illustrative domain because it combines quantitative modeling, regulatory obligations, customer-facing communication, and explainability requirements. Consumer credit is not governed solely by model risk considerations. It is also shaped by consumer protection, fair lending, and adverse-action requirements. Under the Equal Credit Opportunity Act [9] and its implementing regulation, Regulation B [16], banks and other creditors must provide statements of specific reasons when adverse action is taken against applicants or existing borrowers. The use of complex technology does not create an exception to these explanation duties. Nor is it sufficient to provide a generic checklist reason when that reason does not accurately reflect the actual basis for the credit decision, as emphasized by the Consumer Financial Protection Bureau (CFPB) [17].

This domain illustrates why generative AI governance must extend beyond predictive accuracy. Industry practice already suggests that generative AI may be used as a drafting assistant for adverse-action messaging after the relevant decision drivers have been identified [18]. Such a workflow may improve the readability and accessibility of adverse-action explanations, but it also raises concerns about fidelity. A generative AI-generated explanation may be polished, plausible, and consumer-readable, yet still fail to faithfully reflect the principal factors that drove the credit decision. Such failures may produce unfaithful explanations and create legal, compliance, fair lending, reputational, and consumer-harm risks.

This concern motivates the concept of *adverse-action fidelity*, defined here as the degree to which a consumer-facing explanation accurately, specifically, and traceably reflects the principal factors that drove the credit decision when generative AI is involved. Within the broader GAICF, adverse-action fidelity should be understood as a domain-specific example of output fidelity: the general requirement that generative AI outputs remain faithful to approved sources, underlying model outputs, business rules, and accountable human decisions. While adverse-action fidelity is specific to consumer credit, the same logic applies more broadly to other financial workflows in which generative AI transforms technical evidence into business, regulatory, or customer-facing language.

2.3 AI Risk Management and Generative AI Governance

Broader AI governance frameworks provide a complementary lens beyond consumer credit. The Artificial Intelligence Risk Management Framework (AI RMF 1.0) published by National Institute of Standards and Technology (NIST) sets up core 4-step functions – govern, map, measure, and manage – to manage the risk of AI tools across the life-cycle [11]. The Financial Services AI Risk Management Framework (FS AI RMF), developed by the Cyber Risk Institute with support from the U.S. Treasury, translates the AI RMF 1.0 into sector-specific control objectives for financial

institutions, emphasizing practical governance of AI-related risks such as bias, opacity, cybersecurity exposure, and operational resilience [19].

Together, these frameworks provide useful cross-sector vocabulary for AI risks management that may not be fully captured by traditional model risk management. However, they do not directly resolve the specific governance problem addressed in this paper: When the Generative AI models are enabled and embedded inside the consumer credit workflows for non-primary tasks, including adverse-action explanation generation, validation documentation or monitoring altering, how the outputs should be controlled. This gap motivates a more targeted framework for Generative AI governance in consumer credit risk.

3 Generative AI Control Framework (GAICF)

In this section, we introduce the Generative AI Control Framework (GAICF) designed for generative AI-enabled business workflows in which an generative AI model is not the underwriting model itself, but still influences how validation evidence, monitoring signals, adverse-action reasons, or human decisions are interpreted and communicated. The framework can be classified into 4 layers as shown in Figure 1 below.

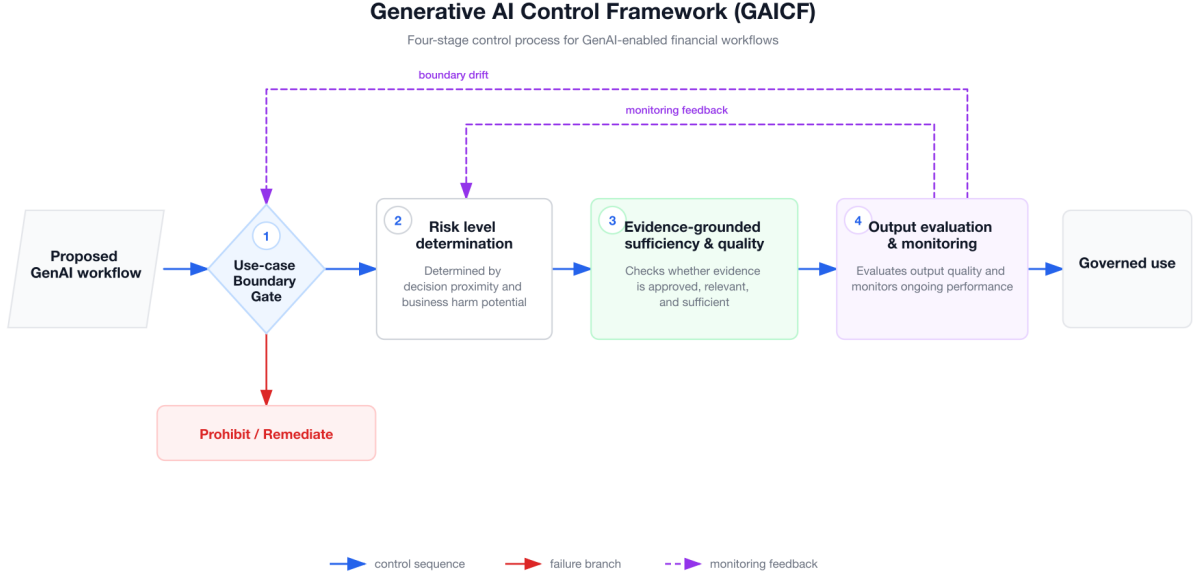


Figure 1: Flowchart of Generative AI Control Framework (GAICF).

3.1 Step 1: Use-Case Boundary Determination

The first layer of the GAICF operates as an entry-control mechanism by establishing the approved-use boundary for deployment. This boundary is aligned with the SR 26-2 principle that sound model governance should begin with a clear understanding of a model’s intended use, limitations, and potential misuse. For generative AI-enabled financial workflows, this means that an institution

should first determine whether the proposed use can be placed in an acceptable, bounded, and controllable role before applying downstream risk controls.

In addition to the inherent risk level of the use case, the approved-use boundary should consider the degree of operational autonomy assigned to the generative AI system. Accordingly, this framework classifies generative AI applications into three operational modes:

- **Collaborative Assistance.** The AI serves as a decision-support tool while humans remain actively involved throughout the workflow. Intermediate reasoning, supporting evidence, and final outputs are subject to human review before any action is taken.
- **Human-Approved Automation.** The AI independently performs most processing tasks, but the final output must receive explicit human approval before it can be used. Human oversight is concentrated at the final decision point, where the human reviewer remains accountable for accepting, rejecting, or modifying the AI-generated output.
- **Autonomous Operation.** The AI executes predefined tasks with limited routine human intervention. Two governance models are distinguished:
 - **Human-on-the-Loop (HOTL).** The AI operates autonomously within approved operating boundaries while humans supervise performance through predefined thresholds, alerts, exception handling, periodic reviews, or risk-based sampling. Human intervention occurs only when abnormal behavior or elevated risk is detected.
 - **Human-out-of-the-Loop (HOOTL).** The AI performs operational tasks without direct human involvement during normal execution. Human responsibilities are limited to system governance, validation, deployment approval, and post-deployment monitoring.

As operational autonomy increases, governance expectations should also increase. In large financial institutions, HOTL and HOOTL uses of generative AI should be highly restricted and subject to enhanced governance. Fully automated generative AI workflows may create material risks because their outputs can influence customer communications, regulatory interpretations, risk assessments, documentation, escalation decisions, and other control processes without meaningful human review. For use cases involving business decisions, adverse-action explanations, compliance interpretation, customer-facing communication, model validation, risk reporting, remediation activities, or other regulated control processes, human review and approval should remain mandatory before the output is used or communicated. Accordingly, this paper focuses only on two governance-relevant deployment patterns: *Collaborative Assistance* and *Human-Approved Automation*. Autonomous Operation, including HOTL and HOOTL arrangements, is treated as outside the permissible deployment scope of the proposed framework unless separately justified under enhanced institutional governance.

The approved-use boundary assessment distinguishes prohibited uses from permissible uses. Prohibited uses are those in which generative AI is placed in an autonomous or insufficiently bounded role such that the institution cannot reliably define, constrain, oversee, or audit its function. In these cases, the issue is not simply that the generative AI may produce inaccurate output, but

that the proposed use lacks a stable governance perimeter. Permissible uses, by contrast, are those in which generative AI operates as a bounded support tool that can be anchored to institutional processes and governed through subsequent evidence, role, validation, monitoring, and auditability controls.

To operationalize this boundary assessment, we propose four minimum gate conditions, as shown in Table 1. These conditions provide the rationale for determining whether a proposed generative AI use case is sufficiently governable to proceed to the remaining layers of the GAICF. A proposed use case should pass the approved-use boundary assessment only when all four gate conditions are satisfied. If any condition is not satisfied, the use case should be prohibited or should not be deployed until the control gap is remediated.

Table 1: Minimum Gate Condition for Permissible generative AI Use

Minimum gate condition	Assessment question	Boundary implication
No autonomous authority	Is the generative AI prohibited from independently making, changing, recommending, or justifying substantive credit, compliance, risk, or customer-impacting outcomes?	If no, the use should be prohibited because the generative AI functions as an autonomous decision or justification mechanism without sufficient human accountability.
Institutional anchoring exists	Can the proposed use be anchored to an approved model, policy rule, reason-code process, control procedure, or accountable human review process?	If not, the use should be prohibited because the institution lacks a recognized source of authority for the generative AI-supported output.
Role can be bounded	Can the generative AI’s function be limited to a defined support role rather than open-ended reasoning, interpretation, recommendation, or decision justification?	If not, the use should be prohibited because it may drift into substantive decision-making, reason selection, policy interpretation, or unsupported justification.
Oversight is feasible	Can the institution maintain sufficient human review, monitoring, audit trail, escalation, and remediation mechanisms for the proposed use?	If not, the use should be prohibited because the institution cannot effectively evaluate, challenge, or remediate the generative AI’s behavior in operation.

The permissible-use assessment translates SR 26-2’s intended-use and misuse-control logic into a generative AI-specific governance gate. Its purpose is to prevent institutions from treating all generative AI applications as controllable merely because they can be tested or monitored after deployment. A use case should be prohibited regardless of testing results if it cannot be constrained, validated, monitored, reviewed, and audited under a stable governance perimeter. In this sense, the approved-use boundary functions as a threshold condition: only generative AI applications that remain within Collaborative Assistance or Human-Approved Automation, and that satisfy the minimum gate conditions, should proceed to the subsequent layers of the GAICF.

3.2 Step 2: Risk Level Determination

The second layer is to determine the appropriate risk level for the permissible use case, which is compatible with the risk-based logic of SR 26-2. SR 26-2 emphasizes that not all models present the same level of risk and that model risk management practices should be tailored to the nature, purpose, use, exposure, materiality, and associated business risks of the model. More material models warrant more comprehensive and rigorous oversight. By analogy, not all permissible generative AI-enabled business workflows should be governed with the same level of risk. An generative AI used for administrative drafting should not be governed in the same controls as an generative AI used to draft adverse-action explanations, interpret monitoring alerts, or support human override decisions. Risk level determination calibrates the intensity of the remaining GAICF controls.

We propose classifying the risk level along two dimensions: decision proximity and consumer harm potential. Decision proximity captures how closely the generative AI output is connected to business decisions, such as underwriting, pricing, or adverse action interpretation. It translates SR 26-2’s model exposure concept into the generative AI-enabled business workflow context by measuring the significance of the generative AI model to business decisions. Business harm potential, on the other hand, extends SR 26-2’s focus on inherent risk and associated business risk. It evaluates the severity of loss that may result from an inaccurate, unsupported, or misleading generative AI output. Together, these two dimensions allow the GAICF to apply governance controls in a risk-based and proportionate manner, consistent with SR 26-2’s view that oversight should be commensurate with model materiality and risk.

The two dimensions can be organized into a risk level matrix to determine the final risk rating: Low, Moderate, High, and Critical, as shown in Table 2. Low-risk use cases have limited decision proximity and limited consumer harm potential, such as grammar check or document formatting. Critical-risk use cases, by contrast, are those that directly affect client-facing explanations or business decision, such as drafting adverse-action notes or producing override rationale. When the two dimensions point to different risk levels, the more conservative rating should generally apply. If both are rated High, the final risk level is elevated to Critical, reflecting the compounded risk created by close decision proximity and substantial business harm potential. Table 3 gives the common use cases and its corresponding risks. Once the risk level is assigned, the institution should determine the following monitoring requirement and strength.

Table 2: Risk Level Matrix for generative AI Use Cases

		Consumer Harm Potential		
		Low	Medium	High
Decision Proximity	Low	Low	Medium	High
	Medium	Medium	Medium	High
	High	High	High	Critical

Table 3: Illustrative Mapping of generative AI Use Cases to Risk Levels

Generative AI Use Case	Decision Proximity	Consumer Potential	Harm	Assigned Level	Risk
Grammar Checking or Document Formatting	Low	Low		Low	
Drafting internal issue list	Low	Low		Low	
Drafting model validation summaries	Medium	Low		Medium	
Summarizing model limitations or validation findings	Medium	Low		Medium	
Preparing monitoring commentary	Medium	Medium		Medium	
Interpreting monitoring alerts	Medium	Medium		Medium	
Extracting risk indicators from data as input	High	Medium		High	
Drafting adverse-action explanations	High	High		Critical	
Generating reason-code narratives	High	High		Critical	
Suggesting human override rationales	High	High		Critical	

3.3 Step 3: Evidence-Grounded Sufficiency and Quality Assessment

Once the risk level is determined, the GAICF evaluates whether the provided evidence is sufficient and in good quality to support the requested generative AI usage and consistent with the usage scope. The determination is necessary because generative AI can use general information or knowledge to fill evidentiary gaps. As a result, the generated output may be fluent and plausible without being supported by the actual underlying evidence [20, 21, 22, 23, 24]. For example, if the approved use case is to summarize a specific validation report, the evidence should be the complete, current, and approved version of the report, instead of a draft or a report related to another models.

This control is aligned with SR 26-2’s expectation that model testing may include a critical assessment of data quality, relevance, and inputs. In the generative AI-enabled credit workflow, the evidence evidence sufficiency and quality check functions as the input assessment as shown in Table 4. Without this assessment, the generative AI generated output may be unsupported and untraceable, which raises a governance regulation concern. The institution should not permit generative AI tool activation unless the provided evidence is approved, relevant to the actual business workflow, sufficiently specific for the requested output, and aligned with the approved use-case scope.

3.4 Step 4: Output Evaluation and Monitoring

After the approved-use boundary, risk level, and evidence requirements have been established, the final layer of the framework focuses on output evaluation and continuous monitoring. The objective of this layer is to ensure that generated outputs are sufficiently accurate, complete, reliable, and appropriately reviewed before they are used in business processes. Consistent with recent studies on generative AI evaluation [25, 26, 27, 28, 29], evaluation should be tailored to both the intended use case and the operational risk associated with the application.

Different generative AI-enabled workflows require different evaluation criteria. For example,

Table 4: Evidence-Grounded Sufficiency and Quality Assessment Concept

SR 26-2 concept	generative AI-enabled Workflow Translation	Assessment question
Data Quality	Input Quality	Is the provided evidence is reliable and controlled?
Data Relevance	Input Relevance	Is the provided evidence is connected to the actual workflow being supported?
Input	Input sufficiency	Is the provided evidence is specific enough to support the requested output?

an generative AI used to summarize a model validation report should be assessed for factual consistency and completeness, whereas an generative AI supporting customer-service interactions should additionally satisfy requirements for response accuracy, latency, and hallucination control. Likewise, the risk classification defined in Step 3.2 determines the required rigor of the evaluation process. Low-risk applications may only require periodic sampling and semantic consistency checks, while high- or critical-risk applications should require continuous monitoring together with mandatory human review before outputs are released.

The evaluation metrics should be selected according to the intended use case, operational autonomy, and risk classification of the generative AI application. Although additional domain-specific metrics may be required, the following metrics represent the minimum recommended set for evaluating generative AI-enabled workflows. Applications with material business impact, regulatory implications, or direct customer interaction should maintain clearly documented human accountability regardless of operational mode. In addition, latency may be included as an optional metric for time-sensitive use cases where response time materially affects business performance, customer experience, or control effectiveness.

The following items define the core evaluation dimensions used in the GAICF. They are not intended to replace task-specific validation metrics, but rather to provide a common baseline for assessing generative AI-enabled workflows across different financial use cases. Depending on the application, these metrics may be evaluated through automated testing, expert review, retrieval verification, benchmark datasets, or post-deployment monitoring. Higher-risk applications should apply these metrics more rigorously and document the evaluation results as part of the governance record.

- **Accuracy** Accuracy measures the degree to which the generated output is factually correct, logically consistent, and aligned with the intended task or reference information. For classification tasks, accuracy is commonly measured as the proportion of correctly classified instances. For generative tasks, accuracy reflects whether the generated content faithfully represents the available evidence without introducing factual errors or misleading statements.
- **Citation Accuracy** Citation accuracy measures the degree to which cited sources actually support the generated statements. This metric evaluates whether citations are present when

needed, whether the cited documents are relevant to the claim, and whether the generated output accurately represents the cited evidence. Citation accuracy is particularly important for RAG systems, policy interpretation, compliance analysis, model validation documentation, and other regulated financial workflows where unsupported or misleading citations may create auditability, compliance, or consumer-harm risks.

- **Completeness (Capture Rate)** Completeness evaluates whether the generated output captures all material information necessary to satisfy the intended objective. For predictive or classification tasks, this characteristic is commonly represented by recall. For generative tasks, completeness measures the extent to which the response includes all required facts, explanations, or supporting evidence without omitting information that could materially affect downstream decisions.
- **Relevance** Relevance measures the extent to which the generated output remains focused on the user’s request and the available context. A highly relevant response contains information that directly supports the intended objective while minimizing unnecessary, redundant, or unrelated content. For classification problems, relevance is closely related to precision, whereas for generative applications it is primarily assessed through expert review or predefined evaluation rubrics.
- **Hallucination** Hallucination measures the frequency or severity of generated content that is unsupported by the provided evidence, external knowledge sources, or verified business information. Hallucinated outputs may include fabricated facts, incorrect citations, unsupported reasoning, or invented references. This metric is typically evaluated through expert review, retrieval verification, or automated fact-consistency checks.
- **Traceability** Traceability measures the extent to which each generated statement can be linked to an identifiable source, approved business rule, retrieved document, or model output. This metric is particularly important for Retrieval-Augmented Generation (RAG) systems and regulated financial applications where generated content must be auditable and reproducible.
- **Latency** Latency measures the time required for the AI system to generate a response after receiving a request. Although latency does not directly reflect output quality, it is an important operational metric for time-sensitive applications such as customer service, fraud monitoring, real-time decision support, and other workflows where delayed output may reduce business effectiveness or control responsiveness.

Table 5 summarizes representative generative AI use cases with their typical risk level and the primary evaluation dimensions.

4 Conclusion

The issuance of SR 26-2 represents an important modernization of U.S. model risk management. By replacing SR 11-7 with a more risk-based and materiality-sensitive supervisory framework, SR 26-2

Table 5: Usage-specific output evaluation and operational mode

LLM Usage	Typical Risk	Operational Mode		Primary Evaluation Dimensions
Internal formatting or editing of non-decisioning materials	Low	Human-Approved	Automation	Accuracy.
Internal training or procedure summarization	Low–Moderate	Human-Approved	Automation	Accuracy; Completeness; Hallucination.
Credit policy summarization for internal users	Moderate	Human-Approved	Automation	Accuracy; Completeness; Relevance; Hallucination; Citation Accuracy (if Retrieval-Augmented Generation (RAG) is used).
Model validation or governance documentation drafting	Moderate	Human-Approved	Automation	Accuracy; Completeness; Relevance; Hallucination; Citation Accuracy (if RAG is used).
Monitoring alert or portfolio review summarization	High	Collaborative	Assistance	Accuracy; Completeness; Human verification before distribution.
Manual review note summarization	High	Collaborative	Assistance	Accuracy; Completeness; Relevance; Hallucination.
Customer-service explanation support using approved scripts	Critical	Collaborative	Assistance	Accuracy; Completeness; Relevance; Hallucination; Citation Accuracy (if RAG is used).
Adverse-action language drafting from approved reason codes	Critical	Collaborative	Assistance	Accuracy; Completeness; Relevance; Hallucination; Citation Accuracy (if RAG is used); Traceability to approved reason codes.
Complaint response drafting involving a business decision	Critical	Collaborative	Assistance	Accuracy; Completeness; Relevance; Hallucination; Citation Accuracy (if RAG is used); Regulatory compliance.
Human override rationale drafting based on approved evidence	Critical	Collaborative	Assistance	Accuracy; Completeness; Relevance; Hallucination; Traceability; Citation Accuracy (if RAG is used).

reaffirms the importance of intended use, materiality, governance, monitoring, and effective challenge in model risk management. However, its exclusion of generative and agentic AI systems from the formal scope creates a new governance challenge for banking organizations and other financial institutions. This exclusion does not eliminate the need for risk controls over these emerging technologies. Rather, it shifts the focus to how financial institutions should govern generative AI-enabled workflows that operate outside the formal model boundary but may still affect regulated banking processes.

This paper addresses that challenge by proposing the Generative AI Control Framework (GAICF), an SR 26-2-compatible governance framework for generative AI-enabled financial workflows. The framework is designed for situations in which generative AI does not directly assign scores, determine capital, or make financial decisions, but nevertheless influences the surrounding control environment. These workflows may include model validation evaluation, monitoring interpretation, policy and procedure summarization, adverse-action language drafting, complaint response preparation, and customer communication support. Rather than treating generative AI governance as a separate compliance exercise, GAICF connects model risk management, responsible AI governance, operational risk, compliance, privacy, third-party risk, and auditability into a coordinated control structure.

GAICF translates the core logic of SR 26-2 into a layered control structure for generative AI applications that operate outside the formal model boundary but remain embedded within regulated financial processes. The framework begins with approved-use boundary determination, which prevents generative AI from being deployed in autonomous or insufficiently bounded roles. It then assigns risk levels based on decision proximity and consumer or business harm potential, allowing governance requirements to be calibrated to the materiality of the use case. The framework further requires evidence-grounded sufficiency and quality assessment to ensure that generative AI outputs are anchored to approved, relevant, and sufficient institutional evidence. Finally, output evaluation and monitoring provide controls over accuracy, completeness, relevance, hallucination, citation accuracy, traceability, human review, and ongoing performance.

The proposed framework is not intended to be a final answer to generative AI governance in financial services. Instead, it provides a starting point for institutions seeking to connect traditional model risk management with emerging responsible AI practices in a banking regulatory context. Future research and supervisory practice should further develop methods for measuring explanation fidelity, testing human reliance on generative AI outputs, auditing agentic workflows, and coordinating governance across different kinds of risks. However, the central conclusion is already clear: generative AI does not need to be the formal financial model to create financial risk. When it shapes the evidence, language, interpretation, control execution, or customer-facing communication surrounding regulated banking decisions, it should be governed accordingly. This is the governance gap that GAICF seeks to address in a manner consistent with the supervisory expectations reflected in SR 26-2.

References

- [1] Giulio Bagattini, Marie Brière, Claudia Guagliano, Carsten Maple, and Alpaya Sabuncuoglu. Leveraging large language models in finance: Pathways to responsible adoption. Report LLMs in Finance, European Securities and Markets Authority and Institut Louis Bachelier and The Alan Turing Institute, June 2025. Published 4 June 2025.
- [2] Yuqi Nie, Yaxuan Kong, Xiaowen Dong, John M Mulvey, H Vincent Poor, Qingsong Wen, and Stefan Zohren. A survey of large language models for financial applications: Progress, prospects and challenges. *arXiv preprint arXiv:2406.11903*, 2024.
- [3] Shijia Jiang, Yongfu Dai, Haochen Jia, Yuxin Wang, and Hao Wang. Intellichain stars at the regulations challenge task: A large language model for financial regulation. In *Proceedings of the Joint Workshop of the 9th Financial Technology and Natural Language Processing (FinNLP), the 6th Financial Narrative Processing (FNP), and the 1st Workshop on Large Language Models for Finance and Legal (LLMFinLegal)*, pages 371–384, 2025.
- [4] Muhammed Golec and Maha AlabdulJalil. Interpretable llms for credit risk: A systematic review and taxonomy. *Expert Systems with Applications*, page 130941, 2025.
- [5] Board of Governors of the Federal Reserve System. SR 11-7: Guidance on Model Risk Management. Supervision and Regulation Letter SR 11-7, Board of Governors of the Federal Reserve System, April 2011. Issued April 4, 2011.
- [6] Board of Governors of the Federal Reserve System. SR 26-2: Revised Guidance on Model Risk Management, April 2026. Accessed: 2026-05-23.
- [7] Ali Fatemi and Iraj Fooladi. Credit risk management: a survey of practices. *Managerial finance*, 32(3):227–233, 2006.
- [8] Jose A. Lopez and Marc R. Saidenberg. Evaluating credit risk models. *Journal of Banking & Finance*, 24(1):151–165, 2000.
- [9] United States Congress. Equal Credit Opportunity Act. Pub. L. No. 93-495, Title V, § 503, codified as amended at 15 U.S.C. §§ 1691–1691f, 1974. United States Code, 2011 Edition. Accessed: 2026-06-03.
- [10] U.S. Government Publishing Office. United States Code, 2011 Edition, Title 15, Chapter 41, Subchapter IV: Equal Credit Opportunity. <https://www.govinfo.gov/content/pkg/USCODE-2011-title15/html/USCODE-2011-title15-chap41-subchapIV.htm>, 2011. 15 U.S.C. §§ 1691–1691f. Accessed June 22, 2026.
- [11] National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework (AI RMF 1.0), January 2023. Accessed: 2026-05-23.
- [12] National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1), July 2024. Accessed: 2026-05-23.

- [13] European Parliament and Council of the European Union. Regulation (EU) 2024/1689 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act), 2024. Accessed: 2026-05-24.
- [14] Board of Governors of the Federal Reserve System and Office of the Comptroller of the Currency. SR 11-7: Guidance on Model Risk Management, April 2011. Accessed: 2026-05-24.
- [15] Su Wang, Pin Qian, Yihang Chen, Junxian You, Xiaoyuan Wang, Xiaochong Jiang, Lifei Liu, Haoran Yu, and Jingzhou Xu. When safe skills collide: Measuring compositional risk in agent skill ecosystems, 2026.
- [16] Consumer Financial Protection Bureau. 12 CFR Part 1002 – Equal Credit Opportunity Act (Regulation B), 2024. Most recently amended August 2, 2024. Accessed June 6, 2026.
- [17] Consumer Financial Protection Bureau. CFPB Issues Guidance on Credit Denials by Lenders Using Artificial Intelligence, September 2023. Accessed June 6, 2026.
- [18] Upstart. How AI Generates More Accurate and Explainable Adverse Action Notices, 2024. Accessed June 6, 2026.
- [19] Cyber Risk Institute. Financial Services AI Risk Management Framework, 2025. Accessed June 6, 2026.
- [20] Alessandro Stolfo. Groundedness in retrieval-augmented long-form generation: An empirical study. In *Findings of the Association for Computational Linguistics: NAACL 2024*, pages 1537–1552, 2024.
- [21] Joshua Maynez, Shashi Narayan, Bernd Bohnet, and Ryan McDonald. On faithfulness and factuality in abstractive summarization. In *Proceedings of the 58th annual meeting of the association for computational linguistics*, pages 1906–1919, 2020.
- [22] Chirag Agarwal, Sree Harsha Tanneru, and Himabindu Lakkaraju. Faithfulness vs. plausibility: On the (un) reliability of explanations from large language models. *arXiv preprint arXiv:2402.04614*, 2024.
- [23] Yihang Chen, Pin Qian, Su Wang, Sipeng Zhang, Huan Xu, Shuhuai Lin, and Xinpeng Wei. Does rag know when retrieval is wrong? diagnosing context compliance under knowledge conflict, 2026.
- [24] Pin Qian, Su Wang, Xiaoyuan Wang, Yihang Chen, Wenxuan Xu, Qiaolin Yu, Shuhuai Lin, Sipeng Zhang, Junxian You, and Xinpeng Wei. Relevant is not warranted: Evidence-force calibration for cited rag, 2026.
- [25] Percy Liang, Rishi Bommasani, Tony Lee, Dimitris Tsipras, Dilara Soylu, Michihiro Yasunaga, Yian Zhang, Deepak Narayanan, Yuhuai Wu, Ananya Kumar, et al. Holistic evaluation of language models. *arXiv preprint arXiv:2211.09110*, 2022.

- [26] Yupeng Chang, Xu Wang, Jindong Wang, Yuan Wu, Linyi Yang, Kaijie Zhu, Hao Chen, Xiaoyuan Yi, Cunxiang Wang, Yidong Wang, et al. A survey on evaluation of large language models. *ACM transactions on intelligent systems and technology*, 15(3):1–45, 2024.
- [27] Shibi C Sherin, Pearline S Anubha, Roseline S Abijah, N Kanimozhi, and R Usharani. Metrics, tools and challenges for assessing generative models. In *Generative AI and Creativity*, pages 211–227. Auerbach Publications, 2025.
- [28] Xian Sun, Wei Gao, Yingshuo Wang, Lingdong Kong, Yanhang Li, Zhichao Fan, Zexin Zhuang, Wenlong Dong, Zhiyuan Zheng, Hrishikesh Paranjape, Abhishek Mandal, and Johnny R. Zhang. Beyond accuracy: Measuring bias acknowledgment in chain-of-thought reasoning for responsible ai evaluation, 2026. ICML Workshop on AI4GOOD.
- [29] Yanhang Li, Zhichao Fan, and Zexin Zhuang. When auc 0.998 is not enough: A candidate evaluation protocol for hidden-state probes of indirect prompt injection in multimodal computer-use agents, 2026.